ONE STACK OR TWO?

Readers familiar with policy engines might envision a simpler architecture than the one shown in Figure 13.1, one with a single PEP and PDP handling all authorization decisions across the platform. In such a design, the platform would use one policy engine that loads data for each tenant: each tenant's policy store and relationship graph would be selected dynamically based on the `tenant_id` included in the request. The PDP would evaluate both platform and tenant policies in a single call, returning a single decision to the enforcement point.

That model is entirely feasible. In fact, many production systems evolve to a unified policy layer once the boundaries and trust assumptions are well understood. It reduces network hops and simplifies caching because each request needs only one evaluation.

For the Customer Collaboration Cloud, however, we've split the design into two layers: a global PEP/PDP pair for ACME's platform policies and tenant-specific PEP/PDP pairs for ReBAC sharing. This separation makes the examples clear and emphasizes the distinct responsibilities of each layer.

- Platform authorization determines who can access the service and enforces cross-tenant governance.
- Tenant authorization specifies who can access resources within a tenant and enforces ReBAC rules.

You can think of C³'s dual-layer model as an explanatory zoom-in: it divides what could be one unified stack into two visible layers so that we can examine each in detail.

13.2 Understanding the starting point

The original Customer Collaboration platform worked well because everyone involved—ACME employees and invited customers—shared a single trust boundary. Employees authenticated through ACME's internal